

Protocols and Servers

Part 1 + Part 2 | Combined Report

Analyst: Salah | Platform: TryHackMe | Date: 31 May 2026

ROOMS

Protocols and Servers / Protocols and Servers 2

TARGETS

10.130.181.100 | 10.130.178.90

STATUS

COMPLETE

MODULE

Network Security

ANALYST

Salah (TryHackMe: SalahFr)

DATE

31 May 2026

SCOPE SUMMARY

This report covers two consecutive TryHackMe rooms from the Network Security module. Part 1 examined cleartext protocols (HTTP, FTP, SMTP, POP3, IMAP, Telnet) at the wire level. Part 2 demonstrated real attacks: passive credential sniffing, MITM theory, TLS/SSH as mitigations, and a live dictionary attack using THC Hydra against an IMAP service.

Reconnaissance

Protocol Interaction

Credential Sniffing

Password Attack

SSH / TLS

FLAGS CAPTURED:

THM{e3eb0a1df437f3f97a64aca5952c8ea0} | THM{364db6ad0e3ddfe7bf0b1870fb06fbdf} | THM{5b31ddfc0c11}

■ PART 1 — Protocols and Servers

This room introduced five core application-layer protocols still in active use across corporate networks, IoT devices, and legacy infrastructure. Each protocol was interacted with manually using a raw Telnet client, exposing data transmitted on the wire — including credentials in cleartext. The attacker takeaway: passive network access alone is sufficient to harvest credentials from any of these services.

■ Protocol Inventory

Protocol	Port / Role / Security Risk
Telnet	TCP 23 Remote terminal All traffic cleartext including credentials
HTTP	TCP 80 Web transfer Headers, body, credentials unencrypted
FTP	TCP 21 File transfer Credentials + file contents cleartext; dual-channel
SMTP	TCP 25 Email sending No sender verification; banner discloses server info
POP3	TCP 110 Email retrieval (download+delete) Credentials cleartext
IMAP	TCP 143 Email retrieval (sync) Cleartext; full mailbox history exposed

■ HTTP — Manual Request & Version Disclosure

◆ Commands Executed

```
telnet 10.130.181.100 80
```

```
GET /flag.thm HTTP/1.1
```

```
host: telnet
```

Item	Detail
Flag	THM{e3eb0a1df437f3f97a64aca5952c8ea0}
Server Header	Server: nginx/1.18.0 (Ubuntu)
Risk	Version disclosure enables targeted CVE research against nginx 1.18.0

■ FTP — Authenticated File Retrieval

◆ Commands Executed

```
ftp 10.130.181.100 (frank : D2xc9CgD)
```

```
ls -> get ftp_flag.thm -> exit -> cat ftp_flag.thm
```

Item	Detail
Flag	THM{364db6ad0e3ddfe7bf0b1870fb06fbd}
Server	vsFTPd 3.0.3
Credentials	frank : D2xc9CgD (transmitted cleartext)
Anonymous FTP	Disabled — would be critical if enabled (zero-barrier access)

■ SMTP — Banner Disclosure & Email Spoofing

```
telnet 10.130.181.100 25
```

The flag was embedded in the server greeting banner — disclosed before any command was typed. The server accepted a spoofed mail from: address without verification, demonstrating the technical basis of phishing attacks.

Item	Detail
Flag	THM{5b31ddfc0c11d81eba776e983c35e9b5}
Banner	220 bento.localdomain ESMTP Postfix [flag in banner]
Spoofing	mail from: accepted any address — no sender verification
Relay	External relay denied (correct config); local user frank accepted

■ POP3 & IMAP — Email Protocol Interaction

```
telnet 10.130.181.100 110 -> USER frank -> PASS D2xc9CgD -> STAT
```

Item	Detail
POP3 STAT	+OK 0 0 (0 messages, 0 bytes)
POP3 Port	110 cleartext / 995 encrypted (POP3S)
IMAP Port	143 cleartext / 993 encrypted (IMAPS)
Attack value	IMAP > POP3: persistent access to full mailbox vs one-time snapshot

■ PART 2 — Protocols and Servers 2 (Attack & Defence)

This room demonstrated active attacks against the cleartext protocols from Part 1, introduced TLS and SSH as mitigations, and executed a live dictionary attack using THC Hydra. The CIA triad framed each attack category.

■ Attack Framework — CIA vs DAD

Attack	CIA Pillar	DAD Outcome
Sniffing	Confidentiality	Disclosure — credentials from cleartext traffic
MITM	Integrity	Alteration — data modified in transit
Password Attack	Confidentiality	Disclosure — auth bypassed via credential guessing
DoS	Availability	Destruction — service disrupted or taken offline

■ Sniffing Attack — Passive Credential Capture

Sniffing requires only passive network access. No active exploitation needed — the attacker listens and reads cleartext credentials directly from packet captures.

```
sudo tcpdump port 23 -A # Telnet credentials
sudo tcpdump port 21 -A # FTP credentials
sudo tcpdump port 110 -A # POP3 credentials
# Wireshark filters: telnet / ftp / pop / imap / smtp
```

Item	Detail
tcpdump Telnet filter	port 23
Wireshark IMAP filter	imap
Mitigation	TLS on all services; network segmentation; zero-trust architecture

■ Man-in-the-Middle (MITM) Attack

Technique / Tool	Description
ARP Spoofing	Poisons ARP cache — LAN traffic redirected through attacker
DNS Spoofing	False DNS responses send victims to attacker-controlled servers
Rogue AP	Fake WiFi intercepts all victim traffic transparently
SSL Stripping	Downgrades HTTPS to HTTP — victim unaware, attacker reads plaintext
Etercap	Classic LAN MITM — 3 interfaces (GUI, TUI, CLI)
Bettercap	Modern MITM suite — 3 invocation methods

■ TLS & SSH — Secure Protocol Mitigations

Protocol Upgrade	Port Change
HTTP -> HTTPS	80 -> 443
FTP -> FTPS	21 -> 990
SMTP -> SMTPS	25 -> 465
POP3 -> POP3S	110 -> 995
IMAP -> IMAPS	143 -> 993
DNS -> DoT	53 -> 853 (DNS over TLS — three-letter acronym: DoT)

◆ SSH — Remote Access

```
ssh mark@10.130.178.90 # Password: XBtc49AB
```

```
uname -r # Kernel: 5.15.0-119-generic
```

```
scp mark@10.130.178.90:/home/mark/book.txt . # 415 KB downloaded
```

■ Password Attack — THC Hydra vs IMAP

Given username 'lazier' with no known password, a dictionary attack was launched against IMAP using rockyou.txt — a 14M+ password breach compilation. Hydra parallelises attempts across multiple threads, completing the attack in under 5 minutes.

```
hydra -l lazier -P /usr/share/wordlists/rockyou.txt 10.130.178.90 imap
```

Item	Detail
Target	IMAP — 10.130.178.90:143
Username	lazier
Password Found	butterfly
Wordlist	rockyou.txt (14M+ real breach passwords)
Time	Under 5 minutes
Impact	Full IMAP mailbox access — historical emails, password resets, sensitive data

■ Consolidated Findings

CRITICAL	Weak IMAP Credential — lazle:butterfly Cracked via dictionary attack in under 5 minutes using rockyou.txt — full mailbox compromise
HIGH	Cleartext FTP Authentication frank:D2xc9CgD transmitted unencrypted on port 21 — capturable by any network observer
HIGH	Cleartext POP3/IMAP Authentication All email credentials transmitted without encryption on ports 110 and 143
HIGH	SMTP Cleartext + No Sender Verification Email content exposed; spoofed from: addresses accepted — basis of phishing attacks
MEDIUM	HTTP Version Disclosure Server: nginx/1.18.0 (Ubuntu) — enables targeted CVE research
MEDIUM	SMTP Banner Discloses Server Software Postfix version and hostname disclosed in greeting banner before any authentication
MEDIUM	Telnet Cleartext Exposure Port 23 transmits full session in cleartext — credentials readable by passive observer
LOW	SSH Password Authentication Enabled mark:XBtc49AB — vulnerable to brute force; key-based auth should be enforced
INFO	Anonymous FTP Not Enabled FTP correctly requires credentials — anonymous login disabled

■ Recommended Mitigations

- **Replace cleartext protocols:** Deploy HTTPS, FTPS/SFTP, SMTPS, IMAPS, POP3S. Disable unencrypted variants entirely.
- **Enforce strong password policy:** Minimum 12 characters; block known breached passwords via Have I Been Pwned API.
- **Implement MFA:** Multi-factor authentication on all remote services — especially email and SSH.
- **Disable SSH password authentication:** Use key-based auth exclusively. Set PasswordAuthentication no in sshd_config.
- **Suppress server banners:** Configure nginx, Postfix, and vsFTPD to hide version strings from responses.
- **Network segmentation:** Isolate legacy cleartext systems. Prevent lateral sniffing across VLANs.
- **Account lockout and rate limiting:** Throttle authentication attempts to defeat automated tools like Hydra.
- **Enable HSTS:** HTTP Strict Transport Security prevents SSL stripping MITM attacks on web services.

■ Room Completion Summary

Objective	Result
Rooms	Protocols and Servers + Protocols and Servers 2
Targets	10.130.181.100 10.130.178.90
Flags Captured	3 (HTTP, FTP, SMTP)
Credentials	frank:D2xc9CgD mark:XBtc49AB lazle:butterfly
Services	Telnet, HTTP (nginx 1.18.0), FTP (vsFTPd 3.0.3), SMTP (Postfix), POP3, IMAP, SSH
Kernel	5.15.0-119-generic (SSH — uname -r)
Tools Used	Telnet, ftp, SCP, THC Hydra, rockyou.txt
Key Lesson	Cleartext protocols + weak passwords = trivial credential compromise
Status	COMPLETE

TryHackMe — Protocols and Servers 1 & 2 · Completed by Salah · 31 May 2026 · Network Security Module